

docs/modules/auth-security-policy.md

Кириш хавфсизлиги сиёсати - SPEC

Ҳолат: **ТАСДИҚ КУТМОҚДА** (қарорлар фойдаланувчи билан келишилган; спец (хавфсизлик) + кўригидан кейин карта).

Манба: фойдаланувчи талаби. Мавжуд `lockout` (BR-USR-009, `LoginAttemptListener`) кенгайтирилади + парол муддати сиёсати қўшилади. Бу спец учта мустақил бандни қамрайди.

1. Lockout эскалацияси (мавжуд BR-USR-009 кенгайтмаси)

Ҳозир: 5 кетма-кет хато уриниш → 15 дақиқа қулф; муддат ўтгач счётчик 1 дан. Эскалация ЙЎҚ, барча қулф бир хил.

Янги хулқ (фойдаланувчи қарори - 5+15 ЎЗГАРМАЙДИ): - **1-қулф**: 5 хато → 15 дақиқа (ҳозиргидек). - **2-қулф** (15 дақиқа ўтгач, ЯНА 5 хато): → **1 кун** (24 соат). - 1 кунлик қулф ўтгач ёки муваффақиятли кириш - счётчик ва даража нолланади. - Эскалация даражасини кузатиш: `app_user` 'га `lockout_level` (int, default 0) - ҳар қулфда ошади; муваффақиятли кириш ёки `super-admin unlock` уни нолга туширади. «Тоза давр» қоидаси: охириги қулфдан 24 соат тинчликдан кейин даража ўз-ўзидан 0 (кетма-кет эмас, изоляцияланган хатолар кун сайин 1 кунга қулфламасин). - Муддатлар константа (`LoginAttemptListener`'да): `LOCK_DURATIONS` = {15 дақиқа, 1 кун} - келажакда узайтириш осон.

2. Super-admin эрта unlock

Ҳозир: қулфни фақат вақт ёки муваффақиятли кириш очади - қўлда очиш ЙЎҚ (`UserController`'да `unlock` амали йўқ).

Янги: `POST /users/{id}/unlock` (фақат **SUPER_ADMIN**) - `failed_attempts`, `locked_until`, `lockout_level` тозаланари. `/users` рўйхатида/edit'да қулфланган фойдаланувчида «Қулфни очиш» тугмаси (қулф фаол бўлса). Аудитга ёзилади (`AuditEventType` - янги `UNLOCK` ёки мавжуд нақшда), `WARN log` (099). Ўзини-ўзи `unlock` мантиқан керак эмас (қулфланган `super-admin login` қилолмайди - бошқа `super-admin` очади; ягона `super-admin` ҳолати `runbook`'да, DB даражасида).

3. Ҳар қулфда super-admin'ga notification

Ҳозир: қулф `WARN log` + `LOCKOUT` аудит ёзуви. Актив хабар ЙЎҚ.

Янги: ҳар `lockout`'да `SUPER_ADMIN`'ларга билдиришнома. **Канал: Telegram** (docs/modules/user-profile.md 103 - Telegram улаш) - улаган `super-admin`'ларга bot орқали хабар: «хато уринишдан кейин <муддат>га қулфланди (<вақт>)». Токен/парол ЎЗИЛМАЙДИ (`logging.md` қоидаси). - БОҒЛИҚЛИК: 103 (Telegram) тайёр бўлгандан КЕЙИН тўлиқ ишлайди. 103 гача: билдиришнома фақат `error.log` + аудитда (ҳозирги ҳолат) - бу банд 103 занжирига уланади. - Хабар оқими: `LoginAttemptListener` қулф қўйганда `notification servis`'ни чақиради (`async`, тармоқ хатоси қулфни бузмайди - `WARN log`).

4. Парол муддати сиёсати (янги)

Талаб: фойдаланувчи ҳар 1/2/3 ойда паролини алмаштириши шарт бўлсин; `super-admin settings`'дан белгилайди; қоида БАРЧА фойдаланувчиларга.

- **CompanySettings**'га майдон: `password_max_age_months` (int) - 0 = шарт эмас (default), 1 / 2 / 3. Settings саҳифасида select (SUPER_ADMIN).
- **app_user**'га `password_changed_at` (timestampz) - ҳар парол алмашишида (create + change) янгиланади. Мавжуд фойдаланувчиларда changeset миграцияси уни `now` билан тўлдиради (deploy'дан кейин ҳисоб бошланади).
- **Мажбурлаш**: login'дан кейин `password_changed_at + max_age < now` бўлса, фойдаланувчи мажбурий «парол алмаштириш» саҳифасига йўналтирилади (фақат profile+logout очик) - худди user-profile 102'даги SUPER_ADMIN-мажбурий-2FA нақши (interceptor/filter). Алмаштиргунча бошқа саҳифа очилмайди.
- **Бир марталик admin-парол** (жонли топилма, user-profile 101'да ҲОЗИР қилинади): admin парол қўйганда/reset'да `app_user.must_change_password` =true (changeset 057); login'да ШУ ЖА мажбурий-алмаштириш механизми чиройли alert билан ишлайди (парол-муддати ва must_change бир interceptor). User алмаштиргач флаг тушади.
- `max_age=0` (шарт эмас) бўлса ҳеч ким мажбурланмайди.
- Барча ролга тегишли (SUPER_ADMIN ҳам).

Changeset

Changeset 062 БАНД (реестр: NAVBAT). Иккита ALTER: - `app_user` : `lockout_level` (int default 0), `password_changed_at` (timestampz, миграцияда now); - `company_settings` : `password_max_age_months` (int default 0).

BR кодлар (КАТАЛОГ-АВВАЛ, grep билан)

Парол муддати ўтган (мажбурий алмаштириш); (мавжуд BR-USR-009 lockout кенгаяди, янги код шарт эмас - фақат хулқ). Unlock/notification BR талаб қилмайди (амал + хабар).

Тестлар (минимум)

Эскалация: 1-қулф 15 дақ, 2-қулф 1 кун (LoginAttemptListener unit); `lockout_level` ошиши/нолланиши; super-admin unlock тозалайди (web, фақат SUPER_ADMIN, бошқа роль 403); парол муддати ўтганда login → мажбурий алмаштириш redirect (иккала: муддат бор/йўқ); `max_age=0` да мажбурлаш йўқ; notification servis мок (Telegram улашсиз graceful). Мавжуд SessionCsrfUxWebTest/RoleAccessWebTest яшил.

Тартиб ва боғлиқликлар

1-2-4 бандлар мустақил (login/security). 3-банд (notification) Telegram 103'га боғлиқ - 103 ёпилгач тўлиқ. Тавсия: 1+2+4 битта картада (эскалация+unlock+парол муддати), 3 (notification) 103 дан кейин алоҳида кичик карта. Зона: security модули + CompanySettings + settings.jte. Element: 092 роль тизими (unlock SUPER_ADMIN-only), 101 (парол блоки profile'да).

2-босқич (ҳозир ЭМАС)

IP-даражали чеклов (ташқи deployment); парол тарихи (охирги N паролни такрорлаш тақиқи); «captcha»/секинлаштириш; email орқали lockout notification (SMTP).